GREENLEAF MICROFINANCE

ISO 27001 Gap Assessment | Executive Summary

Client handover • Fictional educational sandbox • 28 October 2026

93	11	82	10
Annex A controls assessed	Partial	Not implemented	Risk scenarios

1 Purpose and scope

GreenLeaf is a fictional community lender whose case study describes a web portal and planned Android app serving 40,000 borrowers. This training assessment reviews the Node.js/Express sandbox, public demonstration endpoints, fictional borrower records, Docker configuration, GitHub repository and available policy reference templates against ISO/IEC 27001:2022 Annex A. No real borrower data or production banking environment was assessed.

2 Principal findings

The simulated gap analysis classified 11 of 93 controls as Partial and 82 as Not Implemented based on available sandbox and documentation evidence. None was verified as fully implemented. These labels describe the limits of this exercise, not established deficiencies at a real lender.

The highest-priority themes are authorization of protected borrower routes (A.5.15 / A.8.3), secure authentication (A.8.5), formal information-security policies (A.5.1), and incident management preparation and response (A.5.24 / A.5.26). The public demonstration endpoints and nonfunctional login must not be mistaken for production-grade access controls.

3 Risk and remediation overview

The Task 3 register records 10 simulated risk scenarios: 5 High and 5 Medium, scored as likelihood × impact on five-point scales. Separately, the Task 4 control-priority mapping identifies 8 High, 8 Medium and 77 Needs Review controls. These are different units of analysis and should not be combined.

Illustrative high-risk links include R-001 (access control, score 12), R-002 (authentication, 12), R-008 (security policies, 12) and R-009 (incident response, 12). Seventy-seven controls need further evidence and risk review before a final priority is assigned.

4 Recommended next steps

Immediate: Restrict borrower-record endpoints behind server-side authentication and authorization; define the role-permission matrix, named owners, and approval of protected-route changes.

Near term: Approve and communicate the draft Access Control and Incident Response policies; establish quarterly access reviews, incident escalation playbooks, and a signed review log.

Evidence-led: Collect the precise artifacts listed in the Evidence Checklist, including approval records, authorization tests, MFA settings, incident exercise reports, and change-control tickets.

Validation: Reassess the 77 Needs Review controls, test control effectiveness in an authorized environment, record risk acceptance or remediation decisions, and revise target dates as evidence emerges.

5 Handover and limitations

The package comprises the assessment scope and authorization statement, policy inventory and Annex A mapping, risk register, gap analysis and remediation workbook, draft Access Control and Incident Response policies, and evidence-collection checklist. The preliminary planning target in the gap report is 20 November 2026; this is a simulated target, not an approved business commitment.

This is an educational simulation, not an ISO 27001 certification audit, a legal compliance opinion, or proof that the proposed controls operate effectively. Policies remain drafts and operational evidence must be independently collected and verified.

Source basis: GreenLeaf Task 6 project brief; Gap_Analysis_Report_Final.pdf (sections 1, 2, 4, 5); Access_Control_Policy.pdf; Incident_Response_Policy.pdf.